

PENETRATION TESTING REPORT

MEDIROZA GENERAL HOSPITAL

Pentester Name	Lawrence Aboagye Okai (Cybersecurity Intern)
Cybersecurity Instructor	Waqas Karim CCIE
Organisation	Networkwalks
Batch	B082 – Week 4 Capstone Project
Engagement Type	External Web Application Penetration Test
Target	https://www.medirozahospital.com
Classification	CONFIDENTIAL

1. Executive Summary

An authorized external penetration test was conducted against the Mediroza General Hospital web application (medirozahospital.com) to identify security vulnerabilities that could put sensitive information at risk. The assessment focused on identifying critical and high-severity weaknesses that could expose patient health information, staff personal details, salary information, and shareholder records.

The assessment identified several significant security risks. Critical SQL injection vulnerabilities were found in the patient portal authentication system, which could allow unauthorized access to patient accounts. An exposed database backup was also discovered, containing sensitive information such as personally identifiable information (PII), salary details, and national identification numbers. Successful exploitation also allowed access to password-protected pathology reports and sensitive internal data.

High-severity findings included weak or default passwords protecting encrypted patient pathology PDF reports, making them vulnerable to password cracking. Sensitive information was also exposed through the reports.txt file and open directory listings. A medium-severity issue involving PDF metadata leakage was identified, which revealed internal system information and staff usernames. Finally, a low/informational finding was identified through disclosures in the robots.txt file.

Overall, the assessment identified six security findings: two critical, two high, one medium, and one low/informational. The most serious issues were the SQL injection vulnerabilities and exposed database backup, as these could result in significant unauthorized access and disclosure of sensitive hospital and patient information.

2. Scope and Methodology

2.1 Scope

The assessment was limited to the public-facing web application at <https://www.medirozahospital.com> including Patient Portal (/patient/), any directories referenced in robots.txt, and downloadable content.

2.2 Methodology

The assessment followed a standard external black-box penetration testing approach, with limited grey-box testing conducted after initial access was obtained. The testing involved several techniques, including reconnaissance, directory enumeration, SQL injection testing, PDF metadata analysis, and offline password cracking of password-protected documents. These techniques were used to identify vulnerabilities and determine the potential impact of unauthorized access to sensitive information.

3. Findings

3.1 SQL Injection in Patient Portal Authentication [CRITICAL]

Location: <https://www.medirozahospital.com/patient/login.php>

CVSS (estimated): 9.8 (Critical) – Authentication Bypass / Data Exposure

The patient portal login form was found to be vulnerable to SQL injection. Testing with crafted input, including common SQL injection payloads such as `admin'--`, caused detailed MySQL error messages to be returned by the application. These errors indicate that user-supplied input is being incorporated into SQL queries without proper sanitization or parameterization.

Further testing demonstrated that vulnerability could be used to bypass the normal authentication process and gain access to the patient portal without valid credentials. Once authenticated, the portal provided access to the “My lab reports” section, which contained multiple pathology reports in PDF format.

Evidence: The application returned detailed MySQL syntax errors, including messages such as *“You have an error in your SQL syntax...”*. Successful authentication was subsequently achieved through SQL injection, providing access to patient laboratory reports.

Impact: This vulnerability represents a complete compromise of the patient portal's authentication mechanism. An attacker could potentially bypass authentication and gain unauthorized access to patient records and laboratory reports, resulting in significant exposure of Protected Health Information (PHI).

Recommendation: Immediately replace dynamically constructed SQL queries with parameterized queries or prepared statements. Detailed database error messages should also be disabled in the production environment. Strong authentication controls, including multi-factor authentication and account lockout or rate-limiting mechanisms, should be implemented. A comprehensive code review should also be performed on all application endpoints that interact with the database.

3.2 Sensitive Database Backup Exposed via Directory Listing [CRITICAL]

Location: https://www.medirozahospital.com/old/mediroza_db_backup_2019.sql

CVSS (estimated): 9.1 (Critical) – Sensitive Data Exposure

The `/old/` directory was found to be publicly accessible, with directory listing enabled. The directory contained a complete SQL database backup named `mediroza_db_backup_2019.sql`, generated by the Mediroza CMS 1.4.2 backup module.

The database backup contained sensitive information from two tables. The `staff` table contained 30 records with employee names, job titles, departments, email addresses, telephone numbers, national identification numbers, monthly salaries, and joining dates. The `shareholders` table contained 10 records, including shareholder names, ownership percentages, number of shares held, and share classes.

Evidence: The `/old/` directory could be browsed directly, exposing the SQL backup file. The `robots.txt` file also referenced the `/old/` directory. In addition, metadata recovered from one of the patient PDFs contained an internal comment indicating that a database backup had been moved to this location.

Impact: Exposure of the database backup represents a significant privacy and confidentiality risk. The information could potentially be used for identity theft, social engineering, targeted attacks against employees, or other forms of abuse. The disclosure of shareholder information could also create additional business and financial risks.

Recommendation: Immediately remove the /old/ directory and all database backups from the publicly accessible web root. Backups should be stored in secure, access-controlled locations that are not directly accessible from the internet. Directory listing should be disabled across the web server, and appropriate access controls should be implemented. The organization should also review its backup management procedures and determine whether affected individuals or regulatory authorities need to be notified under applicable data-protection requirements.

3.3 Weak Passwords on Encrypted Patient Pathology Reports [HIGH]

Location: Patient Portal → Downloadable PDFs (patient_report_1.pdf, _2.pdf, _3.pdf)

CVSS (estimated): 7.5 (High)

Pathology laboratory reports are distributed as password-protected PDFs. The encryption uses PDF R3 / 128-bit RC4. Using standard dictionary attacks (pdf2john + hashcat / online crackers), the following weak passwords were recovered:

- patient_report_1.pdf → password
- patient_report_2.pdf → 123456
- patient_report_3.pdf → !@#%\$%^&

Once opened, the reports contain full patient names, dates of birth, patient IDs, referring physicians, lab reference numbers, and detailed test results (haemoglobin, cholesterol panels, ferritin, etc.).

Recommendation: Replace predictable document passwords with strong, unique, randomly generated credentials where password-protected documents must be used. Modern encryption standards such as AES-256 should be preferred over legacy RC4-based encryption. Where possible, sensitive reports should instead be provided through an authenticated patient portal using appropriate access controls rather than relying on shared PDF passwords. Staff should also receive guidance on secure password practices.

3.4 Information Disclosure via robots.txt and Open Directories [HIGH]

Location: /robots.txt, /patient/, /old/, /staff/

CVSS (estimated): 7.2 (High)

The application's robots.txt file disclosed several sensitive application paths, including /patient/, /staff/, and /old/. Although robots.txt is not an access-control mechanism, publishing these paths provides useful information to attackers during reconnaissance.

Directory listing was also enabled in multiple locations, including /old/ and /patient/. This exposed file names, modification dates, and application components such as error_log, download.php, login.php, and portal.php. The /old/ directory also exposed the critical database backup described in Finding 3.2.

Impact: The exposed directories and file names make it easier for an attacker to understand the application's structure and identify potentially vulnerable or sensitive resources. This information

can significantly reduce the effort required to map the external attack surface and identify additional attack opportunities.

Recommendation: Review and sanitize robots.txt so that it does not unnecessarily reveal sensitive application paths. Directory indexing should be disabled across the web server, for example by using the appropriate server configuration such as Options -Indexes where applicable. Sensitive directories should be protected through authentication and appropriate access controls rather than relying on their paths being hidden.

3.5 Sensitive Metadata in PDF Documents [MEDIUM]

Location: Downloaded pathology PDF reports

CVSS (estimated): 5.3 (Medium)

ExifTool analysis of the PDF files revealed the following metadata:

- Author / Creator: Mediroza Diagnostics Lab / Mediroza CMS 1.4.2
- Producer: Mediroza Lab Reporting Module
- Keywords: pathology, fbc, patient report
- One report contained Author: j.malik and Comments: “DB backup moved to /old before site migration, do not delete”

The metadata disclosed the CMS version, authors, and operational information that should not have been included in documents distributed outside the organization. In particular, the comment provided useful information that contributed to identifying the exposed database backup.

Impact: Although metadata leakage does not directly provide unauthorized access, it gives attackers valuable information about the organization's technology stack, internal users, and file-management practices. This information could be combined with other findings to support further reconnaissance and targeted attacks.

Recommendation: Remove unnecessary and sensitive metadata from documents before they are distributed externally. A document sanitization process should be incorporated into the report-generation workflow. Internal usernames, system information, and operational comments should not be embedded in production documents. The organization should also review existing publicly accessible documents for similar metadata exposure.

4. Illustrative Attack path

1. **Reconnaissance:** The assessment began by reviewing the robots.txt file, which disclosed several application paths, including /patient/, /staff/, and /old/.
2. **Directory Enumeration:** The /old/ directory was accessible without authentication and exposed the mediroza_db_backup_2019.sql database backup. Reviewing the backup revealed sensitive staff and shareholder information, including personally identifiable information (PII).
3. **SQL Injection:** SQL injection testing was performed against /patient/login.php. The vulnerability allowed authentication controls to be bypassed and provided unauthorized access to the patient portal.
4. **Access to Patient Reports:** After gaining access to the portal, the available pathology reports were identified and downloaded for further security testing.
5. **Password Recovery Testing:** The password protection applied to the PDF reports was assessed using offline password-recovery techniques. Dictionary-based testing successfully recovered weak passwords protecting several documents.

6. **Sensitive Information Exposure:** Once the reports were opened, they were found to contain sensitive Protected Health Information (PHI), including patient names, dates of birth, patient IDs, referring physicians, and laboratory test results.

Overall, the findings demonstrated a clear attack chain in which publicly disclosed information and weak security controls could be combined to progress from initial reconnaissance to unauthorized access and exposure of sensitive organizational and patient information.

5. Recommendations and Remediation

Priority	Action	Timeline
P0 – Immediate	Remove <i>/old/ directory</i> and all <i>SQL backups</i> from web-accessible locations. Disable directory listing.	24 Hours
P0 – Immediate	Patch SQL injection in <i>login.php</i> (and all other DB queries). Use prepared statements.	24-48 Hours
P1 - Urgent	Force <i>strong unique passwords</i> (or remove password protection) for all patient PDFs. Rotate any reused credentials.	7 days
P1 - Urgent	Sanitize <i>robots.txt</i> ; restrict <i>/patient/</i> and <i>/staff/</i> paths; review error handling to suppress SQL errors.	7 Days
P2 - High	Implement <i>metadata stripping</i> for generated documents. Review CMS version (1.4.2) for known vulnerabilities and upgrade.	2-4 Weeks
P2 - High	Conduct <i>full application security</i> review/ code audit. Introduce WAF rules for SQLi. Enable logging & alerting authentication anomalies.	30-60 Days

6. Conclusion

The Mediroza General Hospital web application currently presents a high risk of data breach. Critical vulnerabilities (SQL injection and publicly accessible database backups) combined with weak document encryption allow an unauthenticated external attacker to obtain sensitive staff PII, shareholder information, and patient health records. Immediate remediation of the P0 items is strongly recommended, followed by a broader secure-development and configuration review.